



Optimizing Monitoring Tools

Days 12 & 13

Preventive Surveillance in Cybersecurity (420-D01-AB) · Cohort CYB-01

From the Industry to the Classroom — Building the IT's Future, Today and Together!

What we'll cover

Day 12 — “Taming the Noise”

- Alert fatigue & signal-to-noise
- Reducing false positives, safely
- Tuning alerts: deduplicate, correlate, threshold
- Coverage expansion: find the blind spots
- Into the cloud: CloudWatch & Sentinel

Day 13 — “Scaling Smart”

- Performance-impact analysis (the observer effect)
- Baseline tuning: define normal precisely
- Scaling for larger networks
- Newer tools & plugins for better visibility
- Continuous improvement: closing the loop

Why optimize monitoring at all?

- A monitoring system you can't keep up with isn't protecting you.

Optimization pulls four levers

- Quieter — cut the noise so real threats surface
- Wider — close blind spots in coverage
- Lighter — respect the performance cost of watching
- Measured — prove every change with numbers, then repeat
- Maps to competency EZ01: improving quality, accuracy, coverage, and tooling

KEY TAKEAWAY

Optimization = less junk + more coverage + lower cost, measured and repeated — never “set and forget.”

Lecture 1 — Taming the Noise

Day 12 · 1 hour · EZ01 element 5.4

IN THIS SECTION

- Alert fatigue & signal-to-noise
- Reducing false positives, safely
- Tuning alerts: dedup, correlate, threshold
- Coverage expansion: find the blind spots
- Into the cloud: CloudWatch & Sentinel



1.1 Alert fatigue & signal-to-noise (1/2)

The problem

- A noisy SIEM (Security Information and Event Management) buries real threats under low-value alerts
- A SOC (Security Operations Centre) analyst has finite attention
- Past their limit, alerts go unread — and a real attack hides in the pile

The shape of the problem

- Alert fatigue is when volume, not difficulty, defeats the team

1.1 Alert fatigue & signal-to-noise (2/2)

The numbers that matter

- Signal-to-noise ratio (SNR): $SNR = \text{real threats} \div \text{noise}$
- Analyst capacity: $\text{capacity} = \text{analyst minutes} \div \text{minutes per alert}$
- Danger zone: $\text{untouched} = \text{raw alerts} - \text{capacity}$

The mindset shift

- Tuning does NOT remove real threats — it removes the junk so the real ones become visible

KEY TAKEAWAY

Fewer, better alerts beat more alerts. If nobody can read it, it isn't a detection — it's noise.

1.2 Reducing false positives — safely (1/2)

Definitions

- False positive (FP): an alert that fires on benign activity
- False negative (FN): a real threat that fails to fire — the dangerous one

Two safe, classic techniques

- Allowlist — trust a specific source for a specific rule (never “trust this IP for everything”)
- Suppression rule — mute a narrow, known-benign pattern (e.g., the EICAR antivirus test file)

1.2 Reducing false positives — safely (2/2)

The golden rule of tuning

- Every exclusion must be narrow and documented
- Good tuning is provable: show the real attack still fires after your change

Why “broad” is dangerous

- A broad allowlist becomes a blind spot an attacker will happily use

KEY TAKEAWAY

Cut false positives with a scalpel, not an axe.

1.3 Tuning alerts: dedup, correlate, threshold (1/2)

The four levers

- Deduplicate — fold identical alerts in a time window into one
- Correlate — when related alerts tell one story, raise one incident
 - Example: one IP failing logins across many users = password spray
- Threshold — set “how much is too much” (e.g., $\geq N$ distinct users in a window)
- Severity — rank incidents so humans handle the worst first

1.3 Tuning alerts (2/2)

Why thresholds are a balance

- Too low → false-positive storm
- Too high → dangerous blind spot (you miss the real thing)

Events vs incidents

- Raw alerts are events; incidents are stories worth a human's time
- Dedup + correlation turn thousands of events into a handful of incidents

KEY TAKEAWAY

Raw alerts are events; incidents are stories. Tune to surface the stories.

1.4 Coverage expansion: blind spots (1/2)

A blind spot is as dangerous as a noisy alert

- An attack you can't see is an attack you can't stop
- You can't tune what you never collect

Ask of every asset — do we collect its...

- Logs? NetFlow (who talked to whom, when, how much)?
- EDR (Endpoint Detection and Response) data? DNS (Domain Name System) queries?
- Cloud audit trail?

1.4 Coverage expansion (2/2)

Closing a gap

- On-prem: turn on a log source or deploy an agent
- Cloud SIEM: add a data connector — literally the coverage-expansion button

Where gaps usually hide

- IoT and printers, guest Wi-Fi, branch offices

KEY TAKEAWAY

Every “no” in your coverage matrix is a gap. Rank the worst and close them first.

1.5 Into the cloud: CloudWatch & Sentinel (1/2)

The shift in model

- On-prem: you run the detection (grep the logs, poll the hosts)
- Cloud: you describe the detection once; the platform runs it 24/7

Same idea, two platforms

- The mechanics differ; the tuning skill is identical

1.5 Into the cloud (2/2)

AWS (Amazon Web Services) CloudWatch

- Metric filter counts matching log lines → alarm fires on a spike
- SNS (Simple Notification Service) notifies the SOC

Microsoft Sentinel

- A KQL (Kusto Query Language) analytics rule runs on a schedule → a playbook notifies the team

Frameworks in play: NIST · ISO 27001 · CIS

KEY TAKEAWAY

Cloud monitoring trades “do it yourself” for “declare it once, let it run.” The tuning skill is the same.

Demo 1 — Tame One Noisy Rule (~30 min)

Goal: take one over-firing rule and measure the improvement

Steps

- Capture the before count of a noisy rule
- Apply one narrow allowlist or suppression
- Capture the after count
- Compute the win: $\text{reduction \%} = (\text{before} - \text{after}) \div \text{before} \times 100$
- Prove the real attack still fires

KEY TAKEAWAY

A tuning change you can't measure is a guess. Record before → after → proof.

Hands-on Lab 6 — Day 1 (2 h class + 3 h home)

“Cut the Noise, Close the Gaps” — part of the continuous Course Procedure Manual

Five tasks

- Quantify the noise · Kill false positives safely
- Tune: dedup, correlate, threshold · Script an auto-analysis
- Expand coverage: build the blind-spot matrix

Deliverable: a newcomer-teachable report with all screenshots

Due: June 20 @ 23:59 EST — OmniVox LEA DropBox

KEY TAKEAWAY

Document like a teacher: if a beginner can reproduce it from your report, you've done it right.

Lecture 2 — Scaling Smart

Day 13 · 1 hour · EZ01 elements 5.1, 5.2, 5.3, 5.5

IN THIS SECTION

- Performance-impact analysis (observer effect)
- Baseline tuning: define normal precisely
- Scaling for larger networks
- Newer tools & plugins
- Continuous improvement: closing the loop



2.1 Performance-impact: the observer effect (1/2)

The trap

- More capture + more rules = more CPU (Central Processing Unit) burned
- Past a tipping point the sensor itself drops packets
- You see less while spending more

2.1 Performance-impact (2/2)

Set a budget (policy numbers)

- Stay under: $\text{CPU} \leq 70\%$ and $\text{packet loss} \leq 2\%$

Find the sweet spot

- The highest capture/sampling level that still respects the budget
- Sampling (keep 1 in N) buys headroom — keep all high-severity, sample the bulk

KEY TAKEAWAY

Tune for the most visibility you can afford without choking the sensor doing the watching.

2.2 Baseline tuning: define normal (1/2)

A baseline is “normal” as two numbers

- Mean (the centre) and standard deviation σ (how much normal wobbles)

The maths

- z-score: $z = (x - \text{mean}) \div \sigma$
- 3-sigma rule: flag when $|z| > 3$ ($\approx$ outside 99.7% of normal)
- Normal band: $\text{mean} \pm 3\sigma$

2.2 Baseline tuning (2/2)

The rookie mistake to avoid

- Learn the baseline from calm data only
- Let the attack into the baseline and you teach the system the attack is “normal”

Why z-scores win

- They're relative (sigmas, not raw megabytes)
- A busy server and a quiet one each get a fair, self-scaled threshold

KEY TAKEAWAY

Measure deviation in sigmas, not gut feel. Train on calm data, alert past 3σ .

2.3 Scaling for larger networks (1/2)

The architecture pattern — tiered collection

- 1. Agents/sensors at the edge gather data
- 2. Local collectors filter at the source (drop obvious junk early)
- 3. Aggregators roll up and correlate across many servers
- 4. SIEM / storage keeps what matters for analysis and retention

2.3 Scaling (2/2)

Two scaling rules

- Filter at the source — cheaper than shipping everything then discarding
- Sample low-severity, keep all high-severity — bandwidth follows risk

The anti-pattern

- Don't scale by blindly collecting more

KEY TAKEAWAY

Scale by collecting smarter — filter early, prioritize by severity.

2.4 Newer tools & plugins (1/2)

The modern, open stack (vendor-neutral)

- OpenTelemetry — open standard for metrics, logs, and traces
- Prometheus + Grafana — time-series metrics + dashboards
- Wazuh — open-source XDR/SIEM (host security, log analysis)
- Sigma — write-once, deploy-anywhere detection rules
- Suricata · Zeek · Security Onion — network detection & monitoring

2.4 Newer tools (2/2)

The selection lens

- Open + replaceable + interoperable beats vendor lock-in
- Portable telemetry (OpenTelemetry) and portable detections (Sigma) keep you free

Practical payoff

- Swap a backend without rewriting every rule or re-instrumenting every app

KEY TAKEAWAY

Favor open standards. Portable telemetry and detections mean you're never trapped by one vendor.

2.5 Continuous improvement: closing the loop (1/2)

The detection-engineering loop: `measure → tune → validate → repeat`

The numbers managers respect

- FP rate: `false positives ÷ total alerts`
- Improvement: `(old - new) ÷ old × 100`
- MTTD (Mean Time To Detect) and MTTR (Mean Time To Respond) — both should fall

2.5 Continuous improvement (2/2)

The honest nuance

- Cutting alert volume is not the same as cutting the FP rate (the proportion that's junk)
- Name the laggard metric openly → it becomes next month's target

Validate detections

- Test coverage against MITRE ATT&CK techniques

KEY TAKEAWAY

Security monitoring is never “done.” Score every round; keep the wins, target the laggard, repeat.

Demo 2 — Draw the Normal, Spot the Weird (~30 min)

Goal: build a baseline and compare two cloud dashboard layouts

Steps

- Collect a calm-period sample
- Compute the mean and σ
- Score each hour: $z = (x - \text{mean}) \div \sigma$
- Flag anything with $|z| > 3$
- Sketch the same view in CloudWatch vs Sentinel

KEY TAKEAWAY

A good dashboard makes the 3σ outlier jump off the screen. Design for the eye.

Hands-on Lab 6 — Day 2 (2 h class + 3 h home)

“Scale It Without Breaking It” — completes the Course Procedure Manual

Five tasks

- Performance-impact (CPU $\leq 70\%$, loss $\leq 2\%$) · Baseline tuning (mean $\pm 3\sigma$)
- Scale for a larger network (tiered, filter-at-source)
- Explore newer tools · Compare cloud dashboards & measure improvement

Deliverable: newcomer-teachable report with all screenshots

Due: June 20 @ 23:59 EST — OmniVox LEA DropBox

KEY TAKEAWAY

End with a written, evidence-backed recommendation — what a real analyst hands their manager.

Wrap-Up & Reference

Frameworks · formulas · summary

IN THIS SECTION

- Frameworks & standards recap
- Formula cheat-sheet
- The optimization loop, end to end
- Intellectual property & ethics



Frameworks & standards recap

- NIST / NIST CSF — Identify, Protect, Detect, Respond, Recover
- ISO 27001 — information security management system (ISMS)
- CIS — practical, prioritized security controls
- MITRE ATT&CK — adversary techniques to validate detection coverage

KEY TAKEAWAY

Frameworks turn “we feel secure” into “we can prove coverage.” Map detections to ATT&CK to expose gaps.

Formula cheat-sheet (1/2)

- Signal-to-noise ratio — $\text{SNR} = \text{real threats} \div \text{noise}$
- Analyst capacity — $\text{capacity} = \text{analyst minutes} \div \text{minutes per alert}$
- FP reduction — $(\text{before} - \text{after}) \div \text{before} \times 100$
- False-positive rate — $\text{FP rate} = \text{false positives} \div \text{total alerts}$
- Metric improvement — $(\text{old} - \text{new}) \div \text{old} \times 100$

Formula cheat-sheet (2/2)

- z-score — $z = (x - \text{mean}) \div \sigma$
- 3-sigma rule — flag when $|z| > 3$ ($\approx 99.7\%$ of normal inside)
- Normal band — $\text{mean} \pm 3\sigma$
- Performance budget — $\text{CPU} \leq 70\%$ and $\text{packet loss} \leq 2\%$

KEY TAKEAWAY

Carry these nine. Every optimization decision in this unit reduces to one of them.

Day 12 — quieter & wider

- Cut alert fatigue — raise the SNR
- Kill false positives with narrow, provable rules
- Dedup + correlate events into incidents
- Close coverage gaps; push detections to the cloud

SUMMARY

Day 13 — lighter & smarter

- Respect the performance budget (the observer effect)
- Define normal as $\text{mean} \pm 3\sigma$
- Scale by filtering at the source and prioritizing severity
- Adopt open tools; measure, tune, validate, repeat

KEY TAKEAWAY

Quieter + wider + lighter + measured = monitoring that scales with the business, not against the analyst.

Intellectual property & ethics (1/2)

Intellectual property

- Created by and the exclusive property of Cyber.SoHo Educational Hub
- For registered students' personal educational use; no copying, resale, or redistribution without written permission

No affiliation

- Independent creator; not affiliated with, sponsored by, or endorsed by any company, vendor, certification body, university, or college named here

Third-party links & videos

- Owned by their creators; videos are linked, never re-hosted. Scan any external link with VirusTotal before opening

Intellectual property & ethics (2/2)

Liability

- Material provided “as is,” without warranty; Cyber.SoHo accepts no liability for loss or misuse

Lab ethics — defensive only

- Practise only on systems you own or are authorised in writing to test
- Unauthorised access/interception is a crime: Canadian Criminal Code s.342.1 · US CFAA 18 U.S.C. § 1030
- EU Directive 2013/40/EU · Spain Ley Orgánica 10/1995. Any misuse is solely your responsibility

© Cyber.SoHo Educational Hub. All Rights Reserved.



Up next: Final Review & Exam

This closes the last content unit of the course — review, then the final exam.

From the Industry to the Classroom — Building the IT's Future, Today and Together!

© Cyber.SoHo Educational Hub. All Rights Reserved.